

Evaluation Writeup — HTB Cheatsheet Assistant (RAG)

1. Executive Summary & Retrieval Scorecard

Evaluated against a hand-curated 15-question benchmark (5 broad cheatsheets, 10 specific exploits) over 462 Hack The Box writeups. Ground truth was established independently via raw corpus regex inspection with zero reliance on the pipeline.

Cohort	Recall	Precision	Key Query Performance Highlights
Broad Cheatsheets (Q1–Q5)	0.33	0.85	AD (0.96 P), Hashes (0.96 P), Win Privesc (0.88 P), ADCS (0.84 P / 0.95 R)
Targeted Exploits (Q6–Q15)	0.36	0.58	Perfect 1.00 P on Kerberoasting, EternalBlue, WinRM; 1.00 R on Log4Shell
Overall Macro-Average	0.35	0.67	15 Questions across 462 writeups (Full raw matrix in <code>eval/results.md</code>)

2. In-Depth Precision vs. Recall Analysis

- High-Precision Clusters (\$P \ge 0.84\$):** Active Directory, Windows privesc, and auth queries (Q6 Kerberoasting 1.00, Q7 EternalBlue 1.00, Q14 WinRM 1.00, Q3 AD 0.96, Q5 Password Cracking 0.96, Q12 DCSync 0.86) excel due to discriminative terminology (SPN, certipy, evil-winrm, secretsdump) aligning BM25 and dense embeddings.
- The Top-K Recall Funnel (0.35 Macro-Avg):** Broad cheatsheets (Q1, Q2) have 60–200+ valid machines in ground truth. Constraining retrieval to $k=8$ chunks to protect LLM context limits mathematically caps recall (0.06–0.18). Conversely, specific targets surge (Log4Shell 1.00, ADCS 0.95, Docker 0.80).
- False-Positive Bleeding:** Q8 Log4Shell (0.08 P) and Q15 Samba (0.08 P) suffered from lexical bleeding where generic Java/JNDI and SMB port 445 mentions matched non-exploit writeups.

3. Root-Cause Breakdown of Corpus Anomalies & Fixes

- 97% Stuck Headings:** 449 of 462 writeups lacked newlines before headings (Author ## Recon). A regex pre-pass (re.sub(r'([^\n#r])[\t]*(#{2,4}[\t]+[A-Za-z0-9])', r'\1\n\n2', raw)) un-glued sections, recovering thousands of submerged steps.
- 1.2M-Char "Monster Chunks":** Monolithic writeups without subheadings exceeded API limits. Resolved via a recursive paragraph/line sub-splitter (src/chunker.py) with a strict 2,400-char ceiling preserving code fences.
- 85% Unknown OS Defect:** Markdown image stripping deleted OS icons (![Linux](...)) before parsing, tagging 9,215 chunks as unknown. Reordered extraction before stripping, increasing known OS coverage from 15% to 98.7%.
- Monopolistic Saturation:** Verbose writeups dominated broad query slots. Added source diversification in src/retriever.py (max 1 chunk/machine for broad, 2 for specific).

4. Synthesis Quality & Grounding Audit

- Citation Grounding:** 100% of cited machines in eval/answers_generated.md were verified present in the retrieved context via semantic breadcrumbs ([Machine: <Name> | ...]). Zero hallucinated machines.
- Zero Vulnerability Hallucinations:** Across all 15 questions, 0 hallucinated CVEs and 0 invented CLI flags were produced, enforced by low temperature (0.1) and strict grounding prompts.
- Structured Output:** Answers follow offensive lifecycle ordering (Recon \$to\$ Foothold \$to\$ Lateral Movement \$to\$ Privesc) with working exploit commands and machine attributions.